

DEDAN KIMATHI UNIVERSITY OF TECHNOLOGY
BACHELOR OF BUSINESS INFORMATION TECHNOLOGY
BACK END DEVELOPMENT
CLINIC API WRITTEN ANSWERS
SYLVIA LWAYA
C027-01-0863/2024

QUESTIONS: AUDIT LOG

1. **What information should be logged?**
User id, patient id action performed date and time and ip address
2. **Should audit logs be accessible to all users or only admins?**
Audit logs should only be available to administrators or authorized security personnel because the audit history may contain sensitive information about other users and system activities.
3. **How would you implement this without shutting down the main api?**
The application can record audit events in a separate database table and use asynchronous or background processing to save the logs. This allows the main API operation to complete without waiting for the audit record to be written.

PATIENT ASSIGNMENT

4. **What endpoint would you need to claim a patient?**
The authenticated doctor would be identified from their JWT token, and the endpoint would assign the selected patient to that doctor. Only authorized doctors should be allowed to perform this operation.
5. **Should a doctor be able to unassign a patient?**
Yes, but this should be controlled by authorization rules. A doctor could be allowed to unassign a patient currently assigned to them, while administrators should have broader permissions to assign or unassign patients. This prevents unauthorized changes to patient assignments.
6. **How would you handle a patient who has been assigned to a doctor who is no longer active?**
The system should detect that the assigned doctor's account is inactive. The patient should then be flagged for reassignment or automatically reassigned to another active doctor according to the system's rules. The inactive doctor should not be allowed to access or modify the patient's records.

SECURE PATIENT SEARCH

7. **How would you prevent a doctor from searching patients assigned to another doctor?**

The search endpoint should apply authorization filtering based on the currently authenticated doctor. Instead of returning all patients matching the search term, the system should only search patients whose doctor_id matches the logged-in doctor's user ID

8. **What if two doctors share a patient?**

If the system needs to support multiple doctors per patient, a single doctor_id field would no longer be sufficient. The system should use a many-to-many relationship, such as a separate patient_doctor assignment table containing patient_id and doctor_id.